08 — Thesis — Hard Stop 4

Midpoint Research Evidence Review

CISE 699, Fall 2026

AI-Driven Cybersecurity Risk Management: A Systematic Review of Emerging Threats, Security Controls, and Governance Challenges

Gaurav Sharma

Instructor: Majid Shaalan, Ph.D.

Harrisburg University of Technology

October 25, 2026

1. Narrowed Question and What This Investigation Tests

My research question has not changed since Hard Stop 1 and the Research Transition Bridge: what does the published literature actually show about tracing AI-related cybersecurity threats all the way to specific controls and named governance rules, and where does that chain break down in the two closest existing reviews, Albulayhi and Alkhalifah (2026) and Mokgathi and Ogundele (2026)?

This submission tests two different things, and I am keeping them separate rather than letting one stand in for the other, which is the exact mistake Dr. Shaalan's feedback warned against. The first is a procedural claim: that my search-and-screening procedure, already shown to work on a five-record pilot, still produces clear, defensible, and reproducible decisions when it is run on a larger, real batch of sources. The second is a substantive research claim, and the one the whole thesis depends on: that a specific security control named in the literature can actually be traced to a specific clause of a named governance framework, not just to a general theme. Before this submission, that second claim had no evidence behind it at all, which Dr. Shaalan's feedback named directly as the strongest limitation in my design.

What follows is procedural validation at a larger scale, plus a first, bounded piece of substantive evidence on the governance-mapping question. It is not a finished answer to the research question. A pilot finding about a method is not automatically a substantive answer to the research question, and I am stating that limit here before presenting any results, not after.

2. Research Execution: The Bounded Investigation

2.1 What I ran

I ran the same finalized search string used since Assignment 1 and Hard Stop 1, ‘artificial intelligence’ AND ‘cybersecurity’ AND ‘risk management’, against live, accessible databases, mainly Google Scholar, plus direct lookups on arXiv where Google Scholar surfaced a preprint. I then applied the same decision rule already written into the Screening Tracker's Instructions tab and already used in the Smoke Test 2 pilot: include a source if it is substantively about AI and cybersecurity risk management, threats, controls, or governance, and it fits one of the project's seven categories; exclude a source that falls into one of the three boundaries fixed in the project

charter, primary data collection from a real organization, low-level algorithmic security engineering, or operationally actionable attack detail.

This round logged twelve sources in total: the five already screened in the Smoke Test 2 pilot, plus seven new candidates found and screened for the first time in this round. Nine were included and three were excluded. Every one of the twelve rows has a reason recorded, a hundred percent reason-column completeness, which matters because the tracker's whole point, as the Instructions tab says, is that every decision gets logged, not only the ones that made the cut. The full table is in Appendix A, and the updated workbook itself, Screening_Tracker_Full_Scale.xlsx, is the primary record.

Against the 40-to-80 target this sets, twelve logged sources is a real but partial start, roughly fifteen to thirty percent of the range depending on where the final count lands. Twenty-eight more are needed to reach the low end of the target. I am stating that plainly rather than letting twelve sound bigger than it is.

2.2 How AI assisted this round, in brief

I used Claude to run this round's live database searches and to draft a first-pass include or exclude decision and a reason for each new candidate, applying the rule above exactly as written. I reviewed every one of those drafted decisions against my own rule, and against the source's actual abstract, before accepting it into the tracker and before relying on it anywhere in this submission. This is the same division of labor I used in the Research Transition Bridge and Hard Stop 3: AI helps find and organize candidates, I decide what they mean for my review. Section 7 explains this in full.

2.3 Deviations from the plan, and what they mean

- Two of the twelve sources, Billiris, Gill, and Bandara (2025) and Agarwal and Nene (2025), are arXiv preprints, not journal articles from one of the seven licensed databases named in my project charter. I logged them on content grounds rather than filtering them out, but I am flagging the database type honestly in the tracker's Database/Source column. Whether a preprint should count toward the 40-to-80 target, or needs to be tracked separately until a peer-reviewed version appears, is a real open question I have not decided on my own; it is logged as pending below and in the risk log, not answered.
- One excluded source, Erdogan et al. (2021), is older than the 2023-to-2026 window the rest of my verified literature sits in. Google Scholar's relevance ranking still surfaced it for my search string. I excluded it on content grounds, not by date, which tells me the search string will keep catching older adjacent work during full-scale screening and that date alone is not a safe filter for this review.
- The AMSTAR 2 self-appraisal in Section 3.1 could not be scored on three of its sixteen items because they are specific to statistical meta-analysis, which this review does not perform. I marked those not applicable rather than forcing a score, which is consistent with AMSTAR 2's own guidance that it is not meant to produce a single summed number.

3. First Analysis and Checks

3.1 Is AMSTAR 2 actually the right tool here? A justification, not just a citation

Dr. Shaalan's feedback asked me to justify AMSTAR 2's fit to my particular review design rather than just citing it as a standard tool, and on a closer look, the fit is only partial, which is worth stating directly. AMSTAR 2 (Shea et al., 2017) was built to critically appraise systematic reviews of healthcare interventions that include randomized or non-randomized studies, and several of its sixteen items assume that kind of review: Items 5 and 6 expect study selection and data extraction to be done in duplicate by two independent reviewers, and Items 11, 12, and 15 are about the statistical methods of a meta-analysis.

My review is not a review of healthcare interventions and performs no meta-analysis, so Items 11, 12, and 15 do not apply to it and are marked not applicable rather than scored. Items 5 and 6 are where AMSTAR 2 actually exposes a real limitation in my design rather than a mismatch to wave away: it assumes two independent reviewers, and I am one reviewer. That is exactly the R-02 risk already open in my risk log, still pending my supervisor's decision on whether a self spot-check is an acceptable substitute. I am naming this directly instead of silently marking it satisfied.

The items that do transfer cleanly to a governance-literature review like mine are Item 1 (a clearly defined question and inclusion rule, which I have adapted from AMSTAR 2's clinical PICO format into my own threat, control, and governance scope rule), Item 2 (a method set in advance, with deviations justified, which Section 2.3 above is an example of), Item 4 (a comprehensive, reproducible search, the exact thing the pilot and this round's live search both test), Item 7 (excluded sources listed and justified, which the tracker does for every source, not only the included ones), Item 9 and Item 13 (reading each source with its own methodological limits in mind, and considering that when interpreting results), and Item 16 (disclosing conflicts of interest, not applicable here since this is unfunded coursework, stated rather than skipped). AMSTAR 2 is a reasonable, partially-adapted tool for this review, not a perfect match, and I am treating the parts that do not fit as limitations to disclose rather than boxes to check.

3.2 The governance-mapping pilot: the framework-validation test itself

This is the first-ever test of the single highest-risk, previously untested part of my design: taking a specific control described in the literature and tracing it to a specific function or category of a named governance framework. I ran this on seven of the nine included sources, chosen because each one names a specific mechanism rather than only a general theme. For each one I identified the control the source actually describes, then checked it against the real structure of the three frameworks my method already commits to: the NIST AI RMF's four functions (Govern, Map, Measure, Manage), the eight Annex A control domains of ISO/IEC 42001:2023, and the six functions of NIST CSF 2.0 (Govern, Identify, Protect, Detect, Respond, Recover).

I want to be direct about the grain of this test before showing the table: it works at the function and domain level of each framework, the level I could verify with confidence against the frameworks' own published structure, not yet at the level of a single numbered subcategory or clause, for example AI RMF's GV-1.2 or ISO 42001's A.6.3. Reaching that finer level needs a closer reading of each source's full text against the frameworks' own primary documents, which is exactly the work planned for the full framework-validation pilot in weeks 9 and 10, not something I am claiming here.

Source	Control described	AI RMF function	ISO/IEC 42001 Annex A domain	CSF 2.0 function	Mapping note
Islam et al. (2025)	Explainable/interpretable AI risk-management framework	Map and Govern (overlaps both)	A.7 Human Oversight of AI	Govern	Ambiguous between two AI RMF functions; see Section 4.3.
Zeijlemaker et al. (2025)	AI-enabled anomaly detection and incident response, grounded in the Colonial Pipeline case	Measure	A.6 AI System Lifecycle Controls	Detect and Respond	Clean match at function level; incident framing maps naturally to Detect/Respond.
Jabbar et al. (2024)	AI-integrated risk-management framework for IT project governance	Govern	A.6 AI System Lifecycle Controls	Govern and Identify	Clean match; project-scoped, so generalizing beyond IT projects is untested.
Femi & Medugu (2025)	Adaptive, AI-driven threat detection	Measure	A.6 AI System Lifecycle Controls	Detect	Clean match at function level.
Ouariach et al. (2026)	AI threat detection paired with resilience/recovery	Manage	A.6 AI System Lifecycle Controls	Detect and Recover	Two CSF functions implicated; resilience language spans both.
Billiris et al. (2025)	Privacy risk taxonomy: dataset, model, infrastructure, insider threat	Map	A.6 (data governance) and A.7 (human oversight)	Identify and Govern	Spans two ISO domains; insider-threat category ties to human oversight specifically.
Chodyka et al. (2026)	Organizational AI governance policy, staff skill, shadow-AI control	Govern	A.2 AI Policies and A.4 Resources for AI Systems	Govern	Clean match; the only source in this batch that maps to a single CSF function alone.

3.3 Comparison check: does this chain go further than the two benchmark reviews?

Hard Stop 2 already established, in Section 4.4 of the Design Review Package, that Albulayhi and Alkhalifah (2026) provide the strongest evidence that the traceability gap is real but stop at tiering governance risk categorically, without naming which specific control satisfies which specific clause, and that Mokgathi and Ogundele (2026) treat AI as one item inside a broader IT risk governance review rather than building a dedicated chain at all. I have not re-read either paper in full for this submission, so I am relying on that already-established characterization rather than making a new claim about their internals.

Measured against that bar, the table in Section 3.2 does go one step further: for six of the seven sources it names an actual function or domain of a named framework, not only a category label. That is a real, if small, piece of evidence that the chain this thesis is built to close can actually be built, at least at the function level. It is not evidence that the chain holds at the clause level the final thesis will need, and I am not claiming that it is.

3.4 Negative case: what did not map cleanly

Two excluded sources work as boundary tests of the inclusion rule itself, not just entries in a log. Erdogan et al. (2021) is a systematic mapping study of AI techniques for security risk

assessment, Bayesian networks, neural networks, applied mainly to intrusion and malware detection. It is adjacent to my topic but sits on the algorithmic-engineering side of the exclusion boundary my project charter already drew, so it tests that boundary from the technical side and the boundary held. Agarwal and Nene (2025) proposes a five-layer AI governance model covering regulation, standards, and certification, tested through case studies on AI fairness and AI incident reporting. On a first read this looked like a possible include because of the incident-reporting angle; on the closer re-read recorded in Section 3.5, I excluded it because its subject is AI governance in general, not cybersecurity risk management specifically, which tests the boundary from the governance side. Both boundary cases held, which is some evidence the rule itself is doing real work, not just approving everything that looks topically close.

3.5 Quality check: screening-consistency spot-check

My plan committed to a self spot-check at roughly ten percent of logged sources once a batch was in. Two of twelve is about seventeen percent, so I re-checked more than the committed minimum. The full log is in Appendix B. Both original decisions held, Include for Islam et al. and Exclude for Agarwal and Nene, but the re-check of Agarwal and Nene was a genuine second look at a decision I was not fully sure of on the first pass, not a rubber stamp of an easy call, which is the point of doing it at all. I am treating two agreements out of two as a small positive signal, not as proof the single-reviewer arrangement is reliable at full scale; a meaningful consistency check needs a bigger sample, which Section 4.2 restates.

4. Research Reasoning and Uncertainty

4.1 What this evidence actually shows

The search-and-screening procedure holds up at a larger scale than the five-record pilot: twelve real sources logged, every decision reasoned, a mixed outcome of nine included and three excluded rather than a rubber-stamp pattern. The framework-validation mapping step, untested before this submission, is at least possible: six of seven mapped sources landed on a specific named function or domain of a real governance framework, not just a theme. Both boundary cases in Section 3.4 held. That is genuine, if early, evidence that the thesis's central design is workable.

4.2 What this evidence does not show

It does not show that the mapping holds at the clause or subcategory level the finished thesis will need, only at the function and domain level. It does not show that a mapped control is actually effective, or that an organization using it would be compliant; Dr. Shaalan's feedback drew that distinction directly, and the table in Section 3.2 maps literature claims to framework categories, which is a different and smaller claim than proving effectiveness or compliance. It does not show that the single-reviewer arrangement is reliable, since two spot-checked rows is too small a sample to mean much on its own. And twelve sources is not forty to eighty, so none of this shows what the full screened corpus will look like once sources outside this first, convenience-ordered batch are added.

4.3 An anomaly and a rival explanation

Islam et al. (2025) did not map cleanly to one AI RMF function; it sits across Map and Govern. One explanation is that my mapping method is too coarse to make a clean call. A rival explanation, which I think is more likely given how the AI RMF itself describes explainability as a cross-cutting trustworthiness characteristic rather than a single function's property, is that some controls genuinely belong to more than one function at once, and a forced single-function mapping would misrepresent the source rather than clarify it. I am recording the ambiguity rather than picking one function to make the table look cleaner than the evidence supports.

4.4 Unfavorable evidence, stated plainly

- A quarter of what I screened this round, three of twelve sources, was excluded, including one governance paper that looked like a plausible include on first read. The rule is doing real exclusion work, not just confirming whatever the search turns up.
- Two of the twelve sources are preprints, not peer-reviewed journal articles from the seven databases my charter names, and I have not yet gotten a decision on whether that is acceptable. I am not treating that as resolved.
- One mapped source would not reduce to a single governance-framework function without forcing the evidence, which is itself a limit on how clean this method's output will be at full scale, not just at the pilot stage.

5. Evidence Index and Remaining Plan

5.1 Question to claim, traced

Question	Inputs	Procedure	Output	Claim it supports
Does full-scale screening work beyond a 5-record pilot?	Live Google Scholar and arXiv results for the finalized search string	Applied the documented inclusion/exclusion rule (Screening Tracker Instructions tab) to each result in order	12 logged rows, 9 Include / 3 Exclude, 100% reasons logged (Appendix A)	Procedural: the screening mechanics scale past 5 records with defensible, reproducible decisions
Is the single-reviewer arrangement consistent?	2 of the 12 logged rows, re-selected for re-check	Re-read each source's abstract and reason against the rule, independent of the first pass	2 of 2 agreements, one genuinely close call (Appendix B)	Partial procedural: small positive signal, not proof at scale
Can a control be traced to a named governance clause?	7 Include-decision sources with a specific described control	Checked each control against the real function/domain structure of AI RMF, ISO 42001 Annex A, and CSF 2.0	6 of 7 map to a specific function/domain; 1 is cross-functional (Section 3.2 table)	Substantive, first evidence only: the central thesis chain is buildable at the function level

5.2 Provenance and versions

- Updated screening record: Screening_Tracker_Full_Scale.xlsx (Screening Tracker tab, rows 2–13; Spot-Check Log tab, rows 2–3; Progress Summary tab recalculates all counts automatically).
- Original 5-record pilot: screening-pilot.xlsx, unchanged, kept as the baseline this round builds on.

- Prior checkpoint: Thesis — Research Transition Bridge (Thesis_Research_Transition_Bridge.docx), submitted October 18, 2026, which this submission directly follows through on.
- Prior checkpoint: Hard Stop 3 — Early Implementation Validation Package, and the 22-source verified bibliography in Hard Stop 2 (Assignment 4 Design Review Package, Section 8), which this round's 7 new candidates do not yet duplicate.
- Repository: gsharma1989/CISE--699 (https://github.com/gsharma1989/CISE--699), with a dated commit for this round's tracker update.
- New source citations for this round (7 sources not already in the Hard Stop 2 bibliography) are listed in full in Appendix D.

5.3 Remaining actions, weeks 9 through 14

Stage	Target	Decision point
Now – 2–3 weeks	Continue full-scale screening from 12 toward roughly 30 of the 40–80 target (about 15–20 more sources), at a pace of 8–10 per week	Resolve the preprint question (Section 2.3) with my supervisor before counting arXiv sources toward the target
9–10	Framework-validation pilot at the clause level, not just function level, on 5–8 already-screened sources	Confirm with my supervisor whether the function-level mapping in Section 3.2 is an acceptable intermediate step or needs to be redone at clause level first
11–12	Full framework validation across all screened and categorized sources	Confirm which frameworks the final validation covers (three, or two under the fallback already logged in the Bridge Note)
13–14	AMSTAR 2 self-appraisal finalized, PRISMA 2020 checklist, conclusion	Final read-through with my supervisor before the December 6 submission

The main risk is still time, not method: twelve sources with full reasoning took real effort, and twenty-eight to sixty-eight more at the same standard will take longer than it sounds inside the same eight-to-ten hours a week the course sets aside. The fallback already on record, validating against two of the three governance frameworks instead of all three if time runs short, still stands and is not something I am deciding to use yet.

6. Recorded Walkthrough

The recorded walkthrough, six to ten minutes, will open Screening_Tracker_Full_Scale.xlsx and the governance-mapping table in Section 3.2 on screen and talk through, in my own words, why Islam et al. (2025) was the one source that would not reduce to a single AI RMF function, why Agarwal and Nene (2025) was a genuine second-look case in the spot-check rather than an easy call, and what the twelve-source batch does and does not establish about the thesis's central claim. It will close with the same two open items named throughout this document: the preprint question and my supervisor's still-pending decision on the single-reviewer arrangement. A full speaking script is provided as a separate file, HardStop4_Walkthrough_Script.md, for my own

use while recording; the recording itself will be in my own voice and may depart from the script's exact wording.

7. AI Log and Verification

I used Claude for research support this round, the same way I have throughout this project: running this round's live searches against my finalized search string and pulling candidate sources from Google Scholar and arXiv, drafting a first-pass Include or Exclude call and reason for each of the seven new candidates against the rule I had already written, and helping check the control described in each source against the real, published structure of the three governance frameworks before drafting the mapping table in Section 3.2. It also helped write and organize this document and update Screening_Tracker_Full_Scale.xlsx.

None of that replaced my own judgment. I checked every one of the twelve sources against its own original abstract before relying on it anywhere in this submission, I reviewed each of the seven drafted screening calls myself against my rule, and the Agarwal and Nene case is a real example of that review changing something: my own closer read is what moved it from a tentative include to the documented exclude in Section 3.4 and Appendix B. I also decided which framework function or domain fit best in Section 3.2, including the two cases where I chose to record an unresolved overlap rather than accept a forced single answer. I did not use any AI tool to decide the research question or its scope, to make a final call I was not confident in, to stand in for my supervisor's decisions, or for the recorded walkthrough, which is me speaking, not a generated voice or a script read verbatim. Where something has not actually been decided yet, the preprint question and the single-reviewer arrangement, it is recorded as pending, not resolved, the same standard I have used throughout this project.

Appendix A: Full-Scale Screening Tracker, First Logged Block

Source: Screening_Tracker_Full_Scale.xlsx, Screening Tracker tab, rows 2–13.

#	Title (short)	Year	Database	Category	Decision	Reason (short)
1	Islam et al. — Explainable AI risk-management framework	2025	Google Scholar	Security controls	Include	AI-based framework; explainability ties to Control Selection and AI RMF Map/Govern.
2	Zeijlemaker et al. — How does AI transform cyber risk management?	2025	Google Scholar (verified ref.)	AI-related threats	Include	Grounded in Colonial Pipeline case; verified project reference.
3	Jabbar et al. — AI-integrated cybersecurity risk management for IT projects	2024	Google Scholar	Security controls	Include	On topic; scoped to IT project management.
4	Femi & Medugu — Adaptive cybersecurity risk management via AI threat detection	2025	Google Scholar	AI-related threats	Include	Directly relevant to Threat Identified stage.
5	Ouariach et al. — AI in cyber risk management: threat detection and resilience	2026	Google Scholar	Security controls	Include	Broad coverage of threat detection and resilience.
6	Billiris et al. — Privacy in the	202	arXiv	Privacy risks	Include	Taxonomy of 19 privacy risks;

#	Title (short)	Year	Database	Category	Decision	Reason (short)
	Age of AI: A Taxonomy of Data Risks	5	(preprint)			human error as top contributor.
7	Ramya — AI in Cybersecurity and Data Privacy	2026	Google Scholar	Security controls	Include	Threat-detection and privacy-preserving methods; calls for governance.
8	Chodyka et al. — Impact of AI on Organisational Security Management	2026	Google Scholar	Human/ organizational risks	Include	Shadow AI, staff policy, governance needs.
9	Mannam & Kuai — AI in Cybersecurity: SLR of Threat Detection and Org. Defense	2026	Google Scholar	AI-related threats	Include	Related PRISMA review; comparison point alongside the two benchmark reviews.
10	Erdogan et al. — Systematic Mapping Study on AI-Supported Security Risk Assessment	2021	Google Scholar	Security controls	Exclude	Algorithmic-engineering scope boundary (Bayesian/neural-network techniques).
11	Wolfe et al. — Beyond the Hype: Business Impact of AI Adoption in Cybersecurity	2025	Google Scholar	Human/ organizational risks	Exclude	Primary data collection (survey/interviews) from a named real organization.
12	Agarwal & Nene — Five-layer framework for AI governance	2025	arXiv (preprint)	Governance risks	Exclude	General AI governance, not substantively cybersecurity-specific; re-checked.

Progress Summary (recalculated automatically): 12 total logged, 9 included, 3 excluded, 0 undecided, 28 still needed to reach 40, 68 headroom to 80, reason-column completeness 12 of 12.

Appendix B: Spot-Check Log

Row	Source	Original decision	Re-check decision	Agree?	Notes
1	Islam et al. (2025)	Include	Include (confirmed)	Y	Function ambiguity (Map vs. Govern) noted but does not change the Include call.
12	Agarwal & Nene (2025)	Exclude	Exclude (confirmed)	Y	First pass was a genuine close call on the incident-reporting angle; re-read confirmed exclude.

Appendix C: New Source Citations (APA 7th edition)

Seven sources newly screened this round; not already in the 22-source Hard Stop 2 bibliography.

- Agarwal, A., & Nene, M. J. (2025). A five-layer framework for AI governance: Integrating regulation, standards, and certification [Preprint]. arXiv. https://arxiv.org/abs/2509.11332
- Billiris, G., Gill, A., & Bandara, M. (2025). Privacy in the age of AI: A taxonomy of data risks [Preprint]. arXiv. https://arxiv.org/abs/2510.02357

- Chodyka, M., Ciekanowski, Z., Krecikij, J., Wronka, S., Żurawski, S., & Drapikowska, B. (2026). The impact of artificial intelligence on organisational security management. European Research Studies Journal, 29(2), 595–605.
- Erdogan, G., et al. (2021). A systematic mapping study on approaches for AI-supported security risk assessment. In 2021 IEEE 45th Annual Computers, Software, and Applications Conference (COMPSAC) (pp. 755–760). https://doi.org/10.1109/COMPSAC51774.2021.00107
- Mannam, J., & Kuai, L. (2026). Artificial intelligence in cybersecurity: A systematic literature review of AI-driven threat detection and organizational defense [Conference paper]. AMCIS 2026 TREOs, AIS Electronic Library.
- Ramya, P. (2026). AI in cybersecurity and data privacy: Emerging trends and techniques. Shanlax International Journal of Management, 13(S1-Mar), 195–203. https://doi.org/10.34293/management.v13iS1-Mar.10766
- Wolfe, C., O'Flaherty, B., Ramesh, P., Prakash, K., Zhao, T., Sun, H., Sheehan, K., & Treacy, S. (2025). Beyond the hype: Evaluating the business impact of AI adoption in cybersecurity [Conference paper]. Pre-ICIS SIGDSA Symposium 2025, AIS Electronic Library.